

Nguyễn Phú Thọ

MSSV: 1150080158

Lớp CNPM2:

Link Youtube: <https://www.youtube.com/@akali6054>

THỰC HÀNH LAB 3

nhận diện và ứng phó các mối đe dọa đến an toàn thông tin

A. TỔNG QUAN

1. Mục tiêu

✓ Phân biệt đúng bốn khái niệm: lỗ hổng (Vulnerability), mối đe dọa (Threat), rủi ro (Risk) và tấn công (Attack), đồng thời liên hệ chúng với tài sản cụ thể trên một máy trạm Windows.

✓ Nhận diện năm nhóm nguồn đe dọa trong bài học: hành động vô ý, hành động cố ý, thảm họa tự nhiên, lỗi kỹ thuật và lỗi quản lý.

✓ Quan sát và thu thập bằng chứng cho các nhóm kỹ thuật được trình bày trong bài học: mã độc, tấn công mật khẩu, keylogging, backdoor/persistence, DoS/DDoS, mail bombing, sniffing, man-in-the-middle, spoofing và social engineering/phishing.

✓ Sử dụng Microsoft Defender, Windows Event Log, Sysmon, Autoruns, Process Explorer và Wireshark để thu thập bằng chứng từ endpoint và mạng.

✓ Thực hiện quy trình Baseline → Observe → Detect → Contain → Recover → Verify bằng dữ liệu thử nghiệm thuộc phạm vi bài LAB.

✓ Tạo báo cáo có thể tái lập: ghi rõ phiên bản, lệnh đã chạy, kết quả quan sát, ảnh chụp trực tiếp từ VM/PC, log và SHA-256 của bằng chứng.

2. Kiến thức nền

Năm nhóm mối đe dọa cần phân loại trong báo cáo gồm: hành động vô ý, hành động cố ý, thảm họa tự nhiên, lỗi kỹ thuật (phần cứng/phần mềm) và lỗi quản lý. Bài thực hành không cố gắng “tạo” mọi loại sự cố; thay vào đó, sinh viên thu thập bằng chứng ở những tình huống có thể tái lập an toàn và sử dụng risk register để phân loại các trường hợp còn lại.

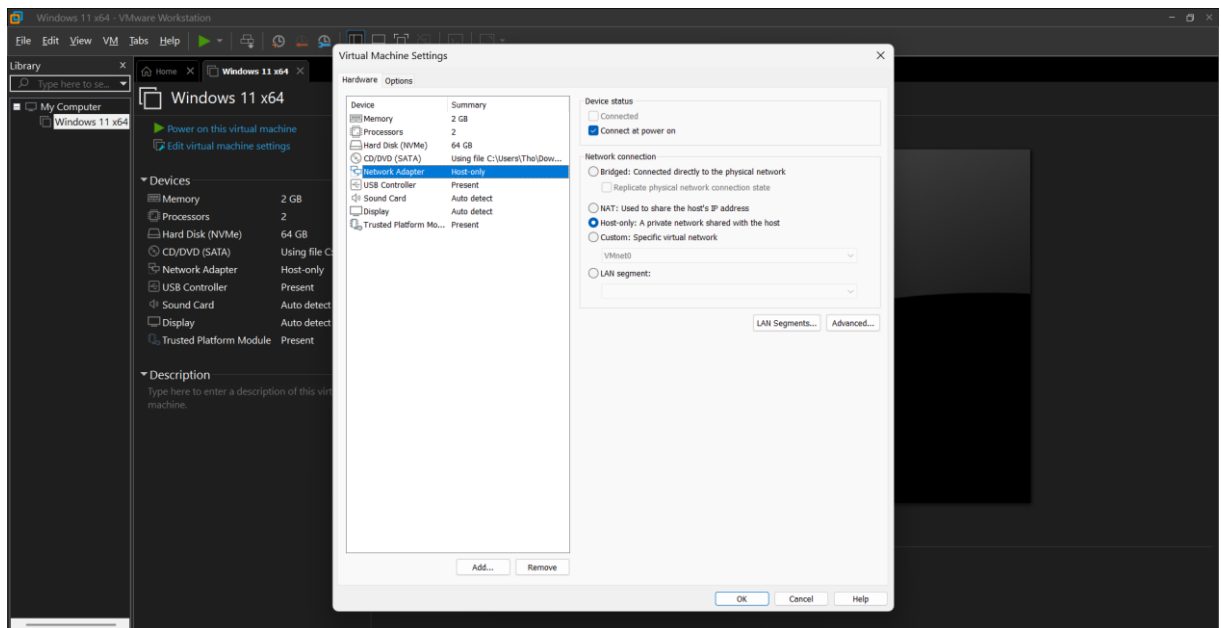
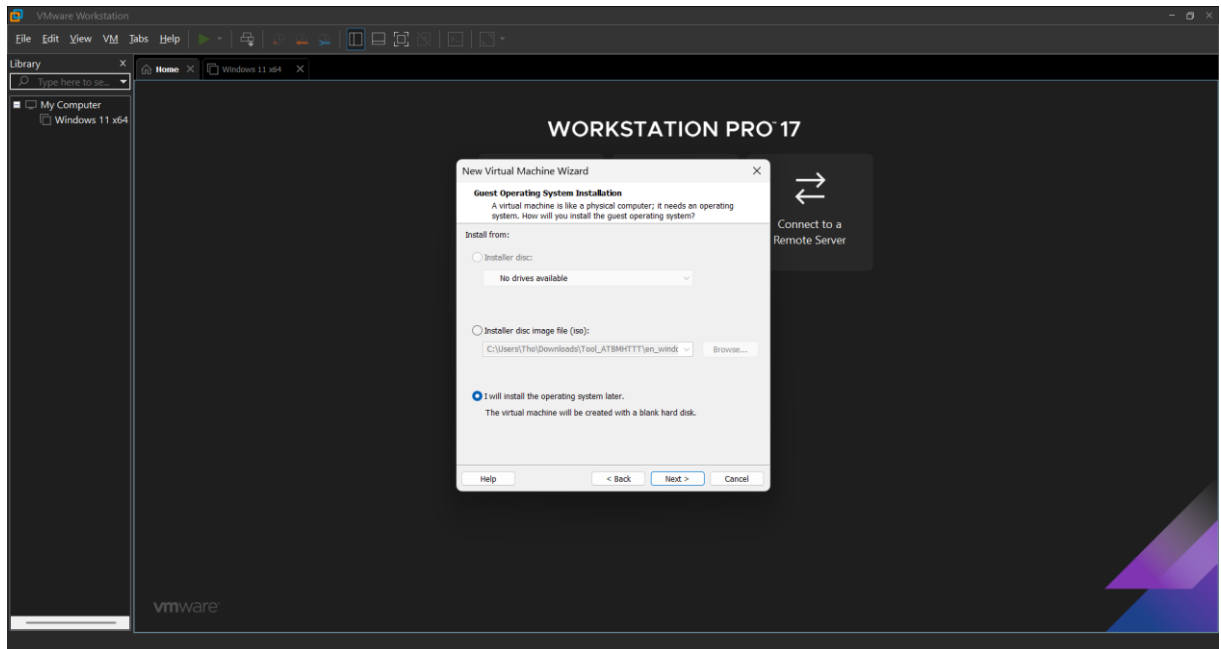
3. Kịch bản

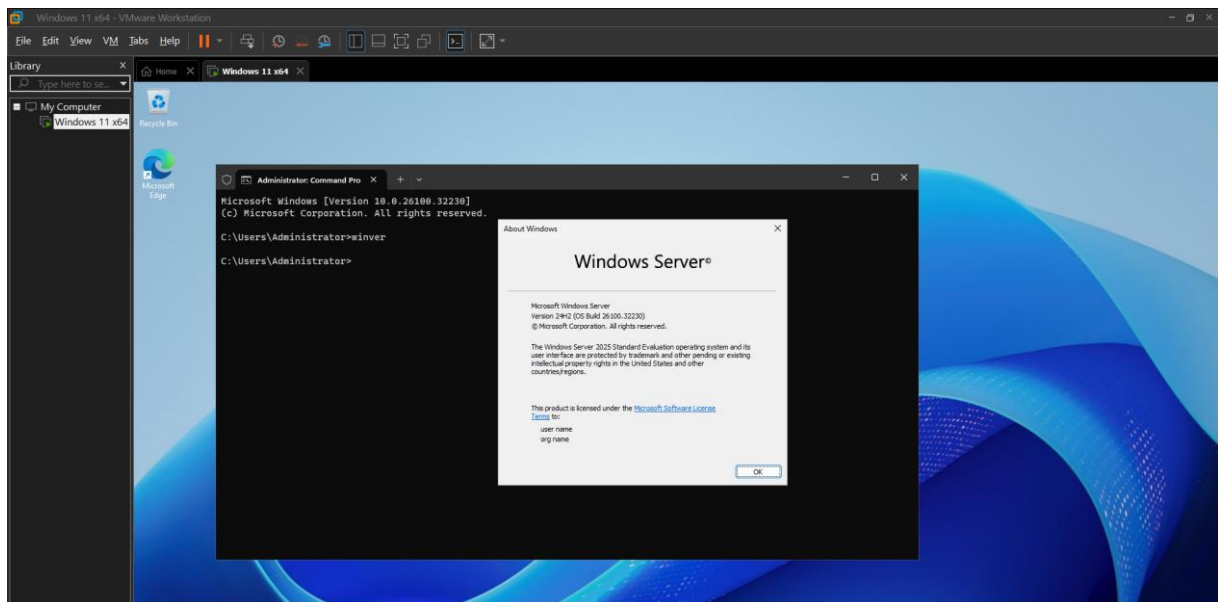
Một máy trạm Windows 11 thuộc mạng đào tạo xuất hiện nhiều dấu hiệu cần đánh giá: cảnh báo của endpoint protection, các lần đăng nhập thất bại, một mục tự khởi động không được phê duyệt, một tiến trình lắng nghe cổng cục bộ, lưu lượng HTTP có dữ liệu đọc được, lưu lượng HTTPS được mã hóa và một thông điệp có dấu hiệu lừa đảo. Sinh viên đóng vai trò nhân sự An toàn và Bảo mật Hệ thống Thông tin, thực hiện triage, thu thập bằng chứng, phân loại mối đe dọa, đánh giá rủi ro và khôi phục máy trạm về trạng thái chấp nhận được. Mục tiêu của kịch bản là làm rõ mối quan hệ giữa khái niệm trong bài học và dấu vết quan sát được trên hệ thống, không phải khai thác máy bên ngoài hoặc né cơ chế bảo vệ.

4. Môi trường và công cụ chuẩn hóa trong bài lab

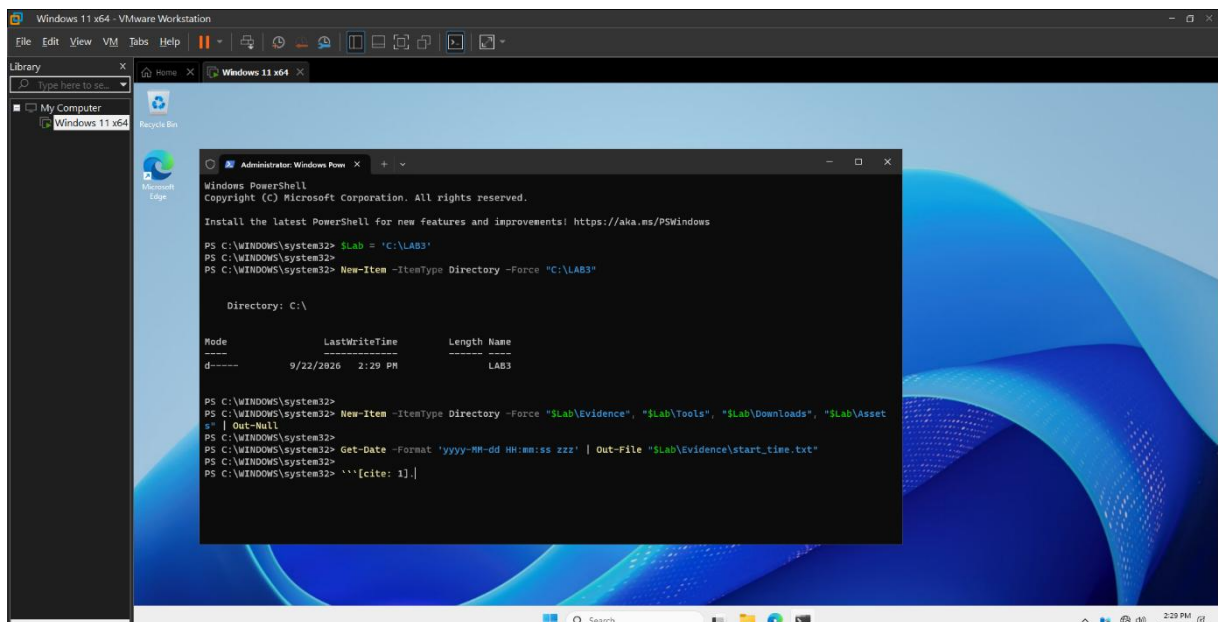
5. Nguồn tài và cách dựng môi trường

Bước 1. Tạo VM Windows 11 25H2 x64. Khuyến nghị tối thiểu 2 vCPU, 6 GB RAM và 64 GB đĩa. Trong VMware Workstation Pro 26H1, chọn VM > Settings > Network Adapter > Host-only. Sau khi cài Windows và cập nhật KB5124008, tạo snapshot tên LAB3_CLEAN_20260914.

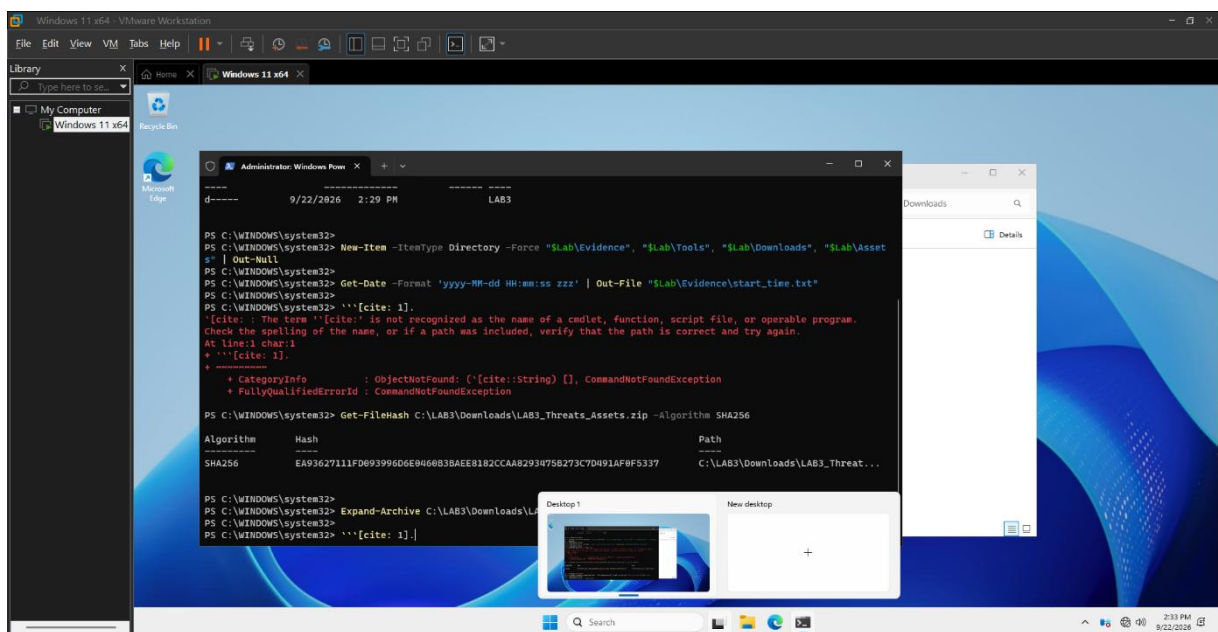
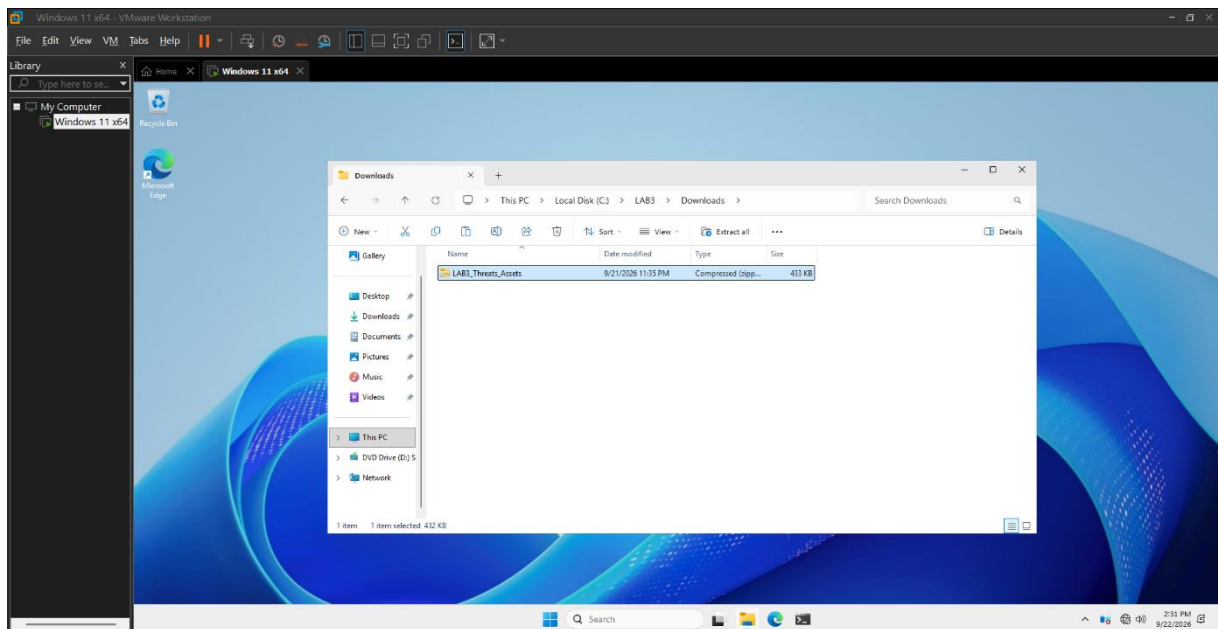




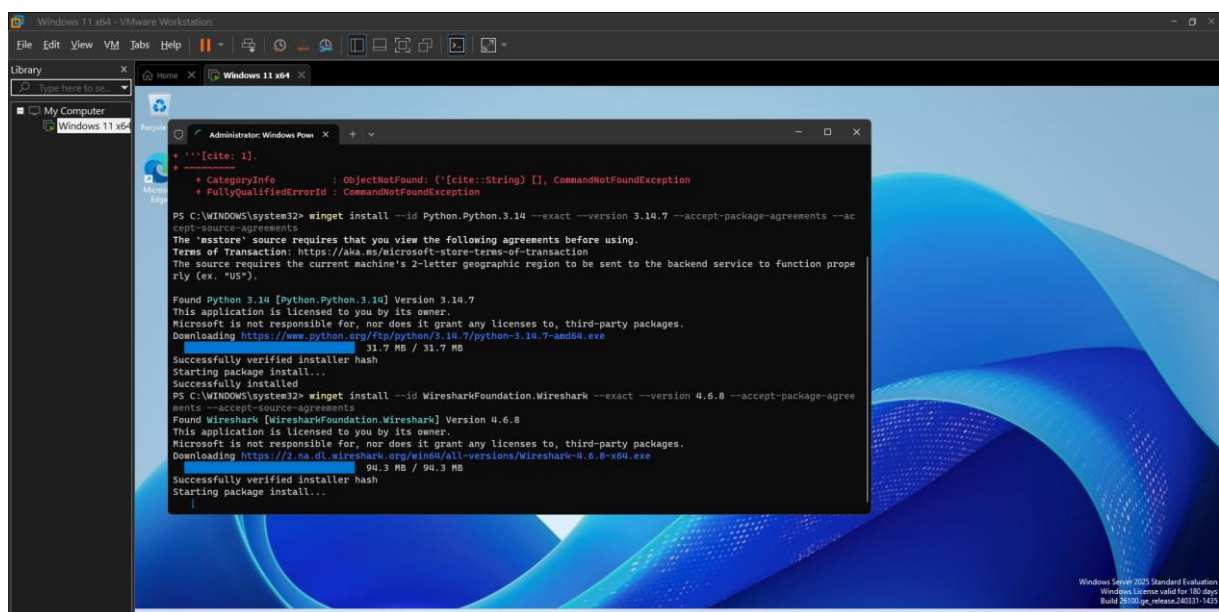
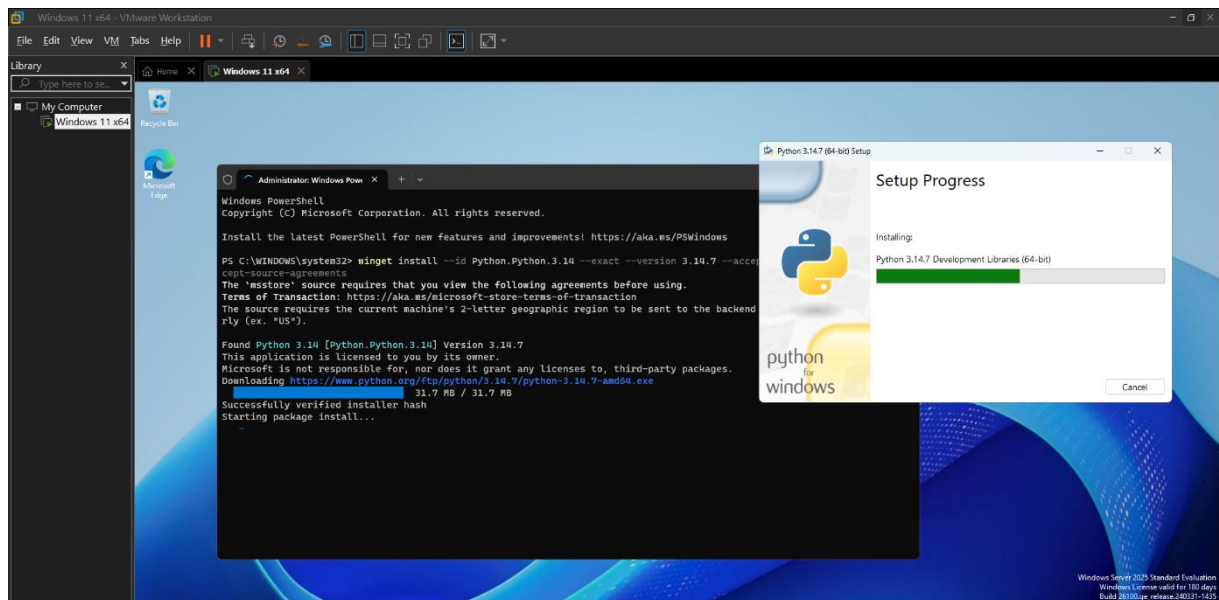
Bước 2. Tạo cấu trúc thư mục bài lab. Mở Start, gõ Windows PowerShell, chọn Run as administrator và chỉ nhập phần lệnh, không nhập dấu nhắc PS C:\>.



Bước 3. Giải nén gói LAB3_Threats_Assets.zip. Sao chép tệp ZIP do giảng viên cung cấp vào C:\LAB3\Downloads, kiểm tra hash trước khi giải nén. Giá trị phải trùng manifest của bài.

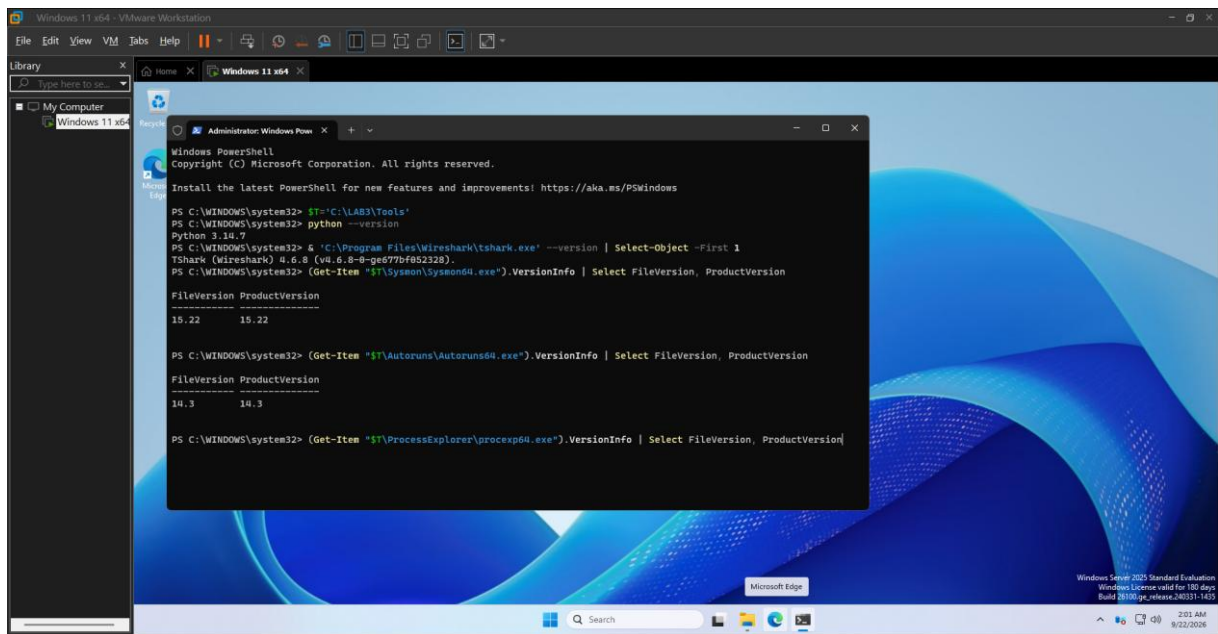


Bước 4. Cài Python 3.14.7 và Wireshark 4.6.8. Nếu phòng máy đã có đúng phiên bản thì không cài lại. Khi trình cài Wireshark hỏi thành phần Npcap, giữ Npcap để có khả năng capture trên Windows.



Bước 5. Tải bộ Sysinternals từ máy chủ Microsoft. Chỉ dùng ba URL download.sysinternals.com dưới đây; không dùng mirror hoặc executable do người khác chia sẻ.

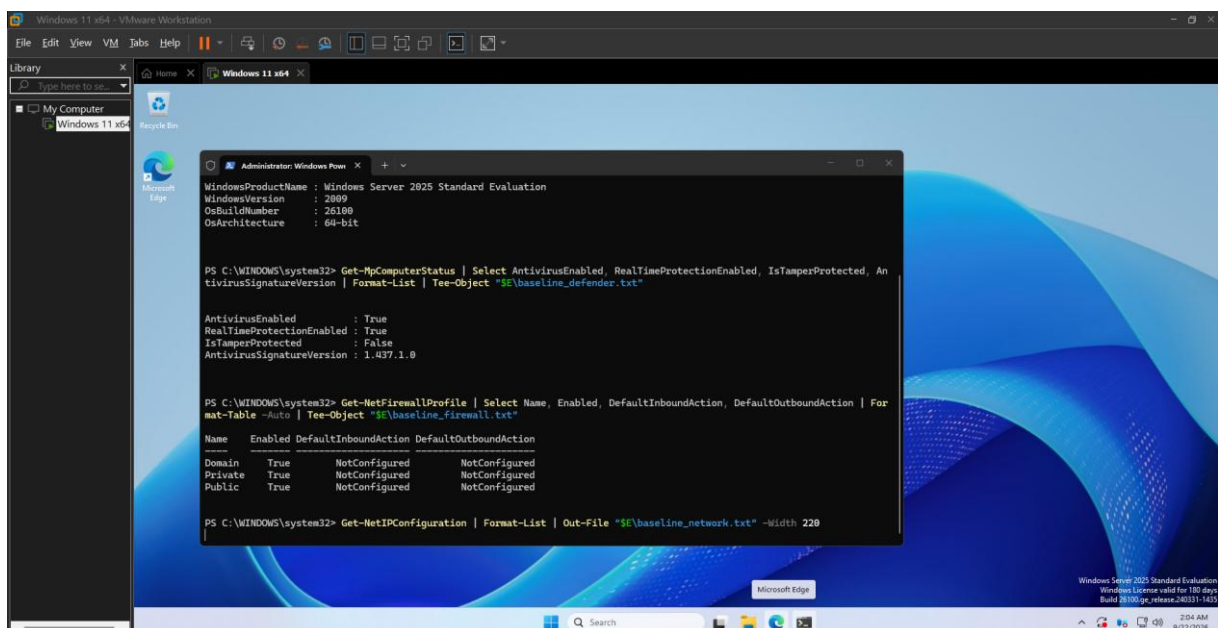
Các packet đã tải.



B. THỰC HÀNH

0. Baseline trước khi tạo tình huống

Baseline là trạng thái tham chiếu để phân biệt thay đổi do bài lab với trạng thái đã tồn tại trên máy. Chạy toàn bộ khối lệnh sau trước khi tạo EICAR, tài khoản thử nghiệm, persistence hoặc HTTP server.



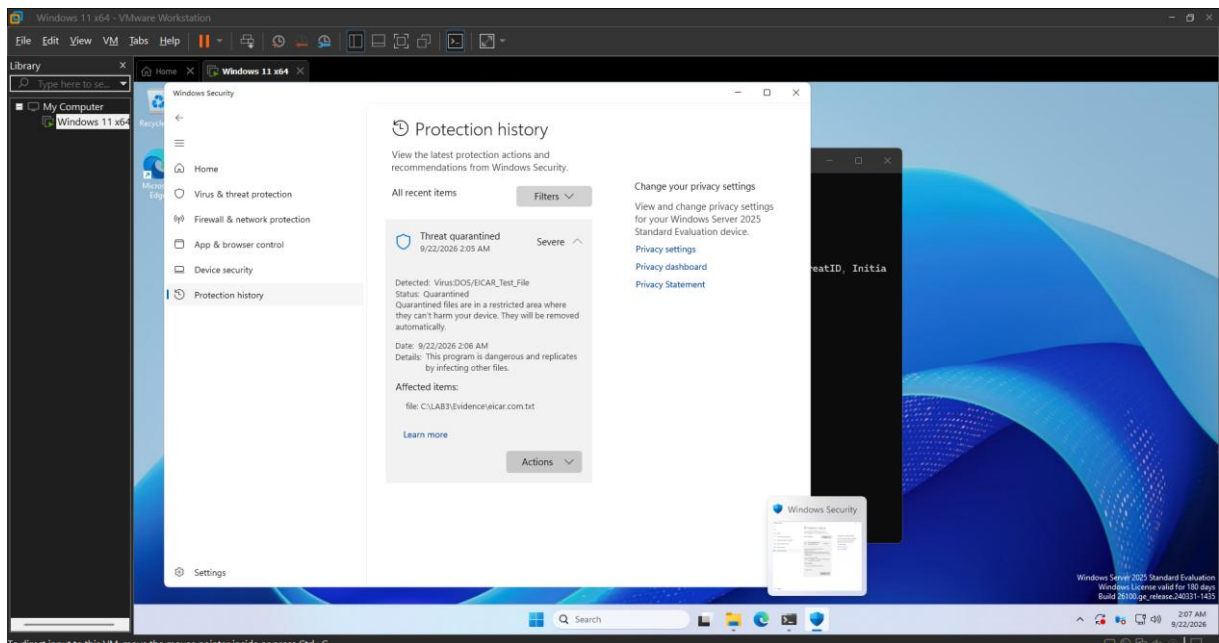
1. Tình huống 1 – Xác định tài sản, lỗ hổng, mối đe dọa và rủi ro Sinh viên lập risk register trước khi thao tác kỹ thuật. Mỗi hàng phải gắn với một tài sản của chính VM

lab và chỉ ra mối quan hệ Asset → Vulnerability → Threat → Risk → Control. Sau đó phân loại nguồn đe dọa theo năm nhóm trong bài học.

2. Tình huống 2 – Mã độc: kiểm chứng chu trình phát hiện bằng EICAR

EICAR Standard Anti-Virus Test File là chuỗi kiểm thử an toàn được các sản phẩm chống mã độc nhận biết. Tình huống này chỉ kiểm tra detection/quarantine và cách lưu bằng chứng; nó không chứng minh VM có malware thật.

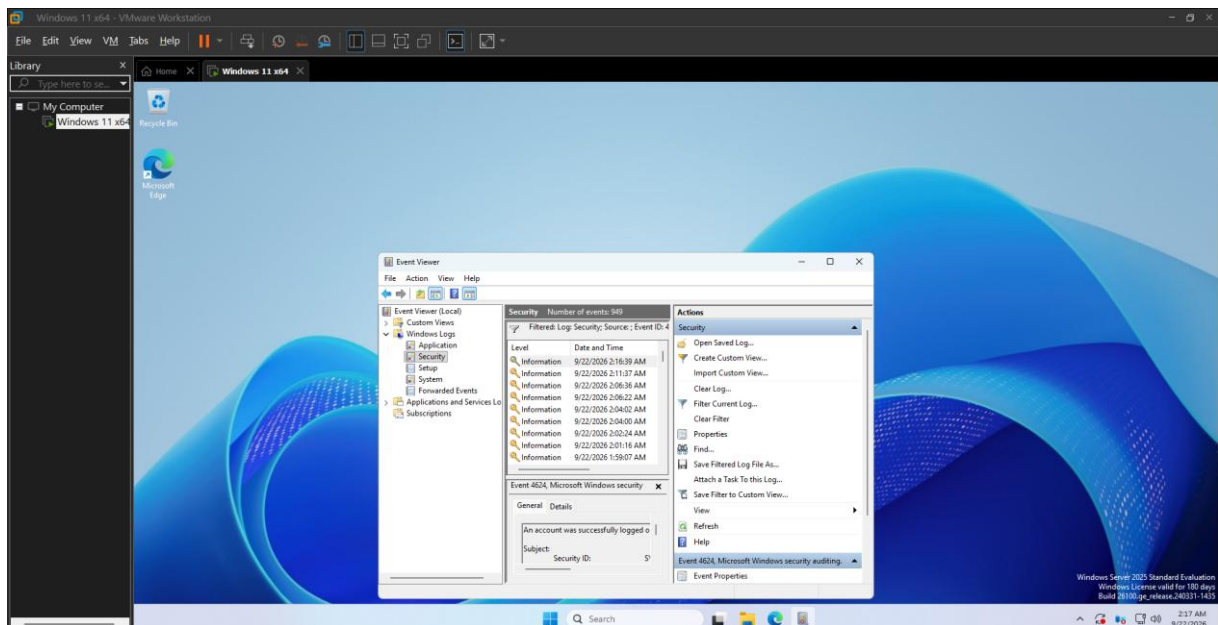
Bước 1. Xác minh Defender đang bảo vệ theo thời gian thực.



3. Tình huống 3 – Tấn công mật khẩu và nguy cơ keylogging

Bài học phân biệt brute force, dictionary attack và key logger. Trong lab, sinh viên không chạy phần mềm dò mật khẩu hoặc keylogger. Thay vào đó, sinh viên tạo một tài khoản cục bộ dành riêng cho bài, sinh các sự kiện đăng nhập hợp lệ/không hợp lệ, đổi credential và dùng log để chứng minh việc phục hồi.

Bước 1. Bật Audit Logon success/failure bằng GUID của subcategory Logon và tạo tài khoản lab3user.



Bước 6. Đổi mật khẩu của lab3user và kiểm chứng. Dùng SecureString. Sau đó thử runas với mật khẩu trước khi đổi (phải thất bại) và mật khẩu sau khi đổi (phải thành công).

```

Microsoft Windows [Version 10.0.22H2.22H2.22H2.22H2]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> $newPw = Read-Host 'Nhập mật khẩu LAB3 sau khi đổi' -AsSecureString
Nhập mật khẩu LAB3 sau khi đổi: *****
C:\Windows\system32> Set-LocalUser -Name 'lab3user' -Password $newPw

```

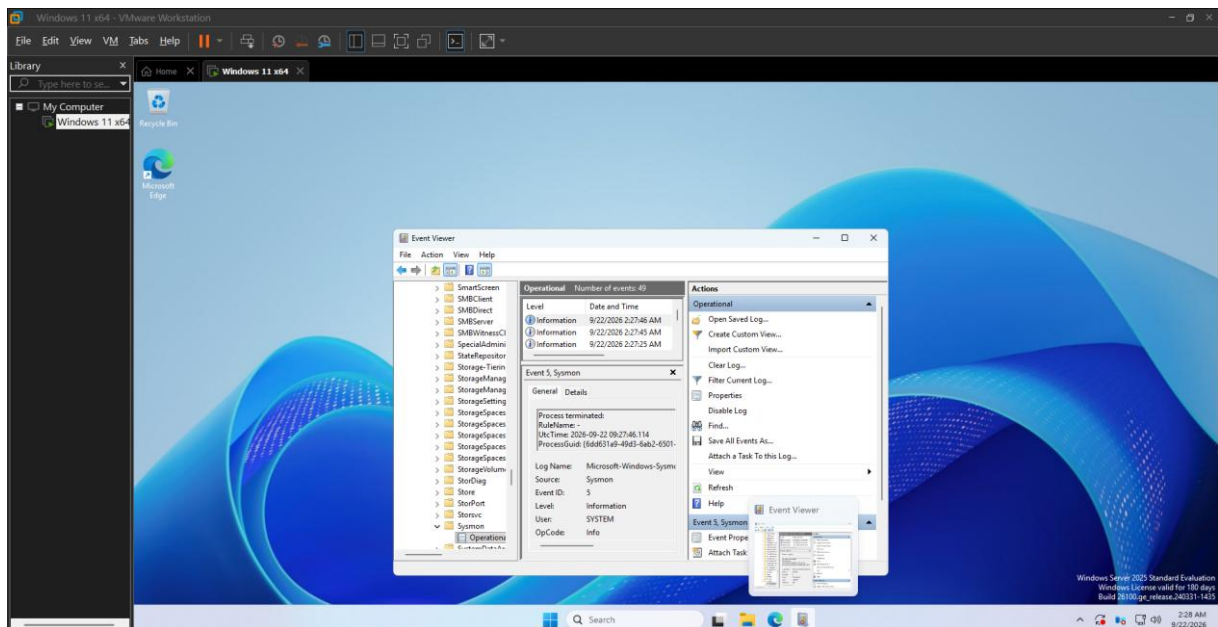
4. Tình huống 4 – Backdoor: nhận diện persistence và dịch vụ lắng nghe

không được phê duyệt Backdoor thường gắn với cơ chế truy cập ngoài luồng quản trị bình thường và có thể duy trì sau reboot/logon. Lab không cài backdoor. Sinh viên tạo hai artefact lành tính có tên LAB3_* và một HTTP listener chỉ bind 127.0.0.1 để học cách phát hiện bằng nhiều nguồn telemetry.

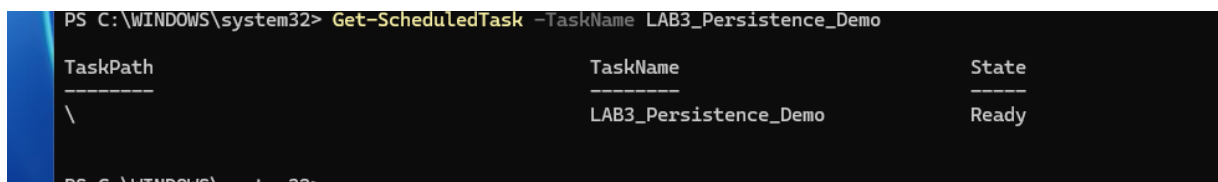
4.1. Cài Sysmon và thu baseline Autoruns

Bước 1. Mở Event Viewer để xác nhận Sysmon. Win+R > eventvwr.msc >

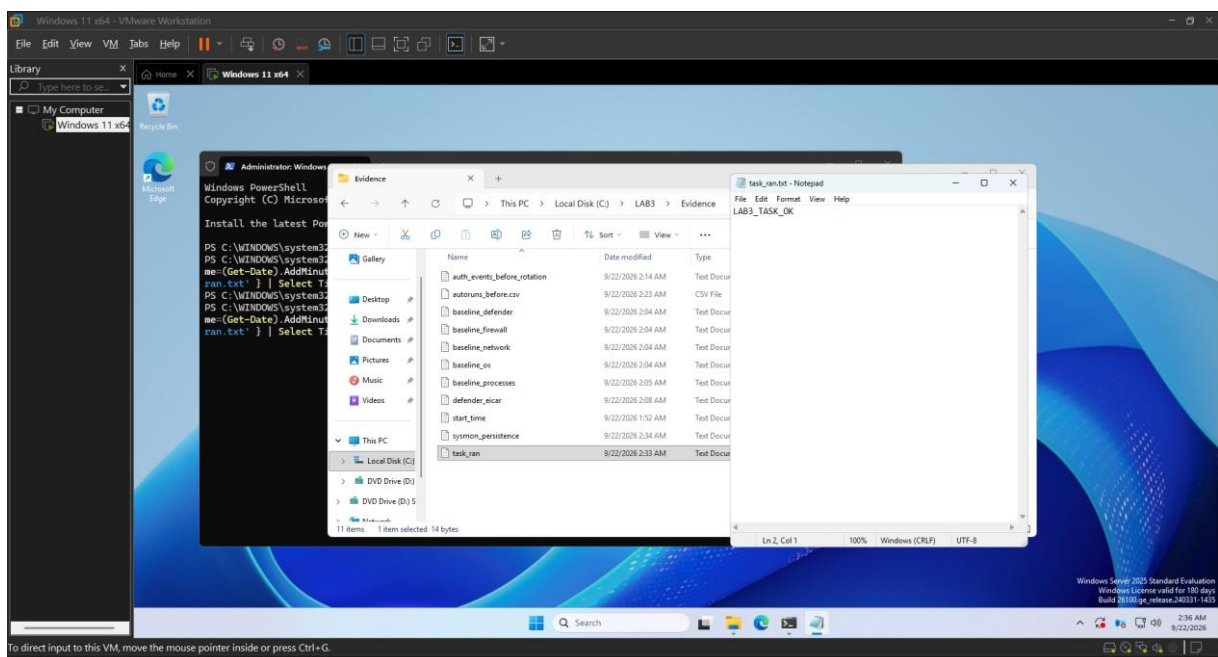
Applications and Services Logs > Microsoft > Windows > Sysmon > Operational. Tạo một tiến trình Notepad rồi refresh; phải thấy Event ID 1.



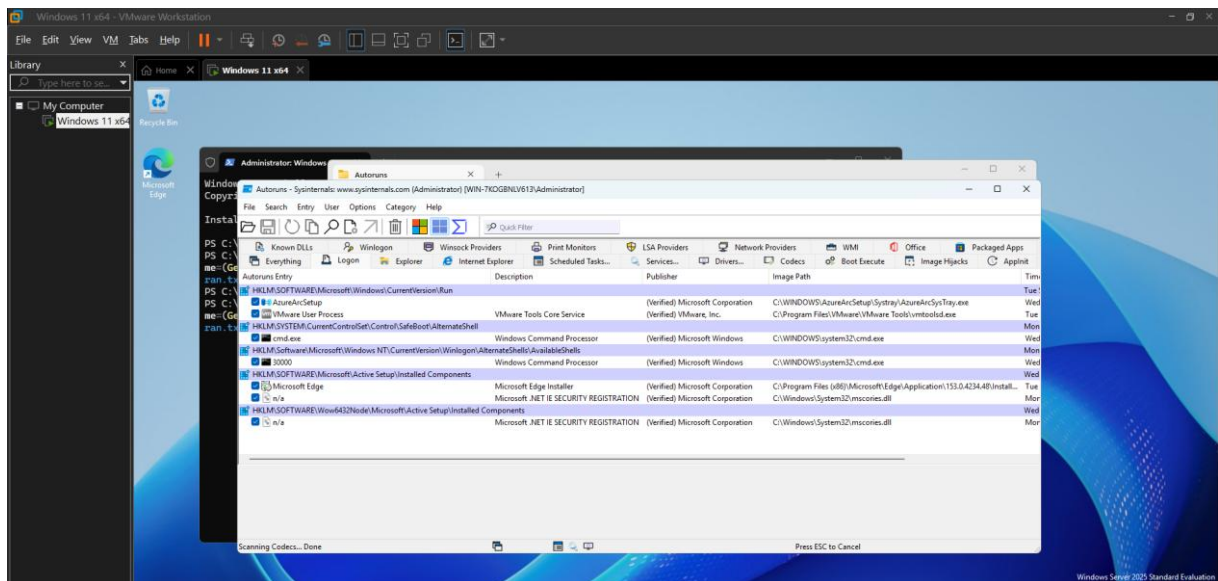
4.2. Tạo persistence lành tính và kiểm tra sau login



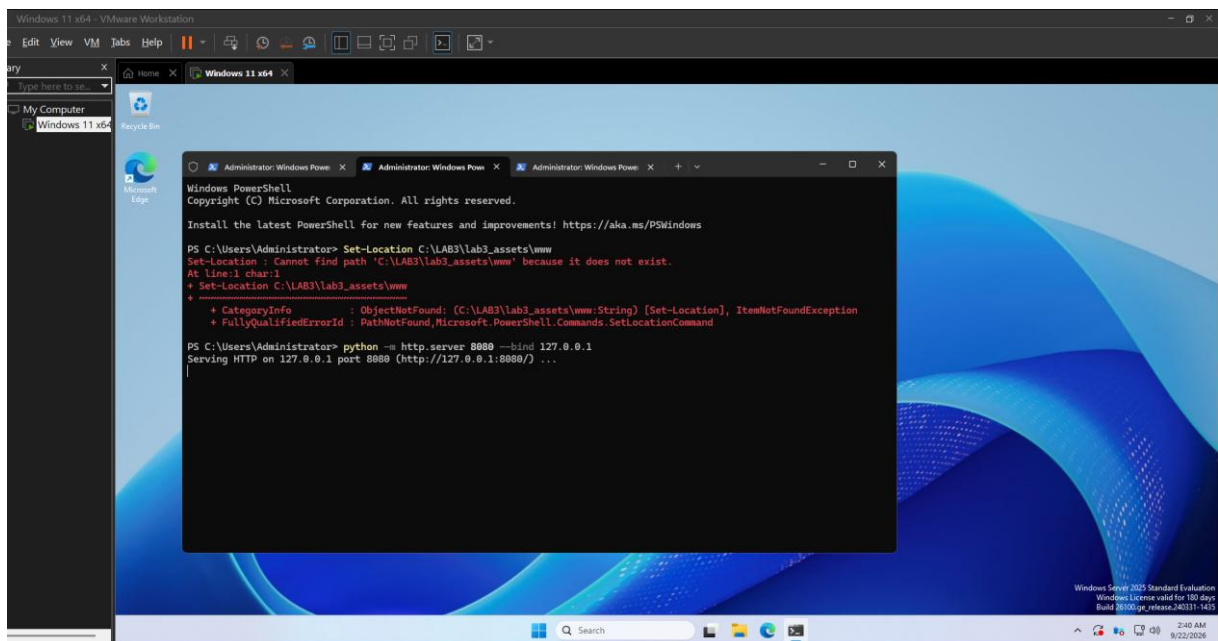
Lưu công việc, restart VM, đăng nhập đúng tài khoản đã tạo task. Sau login, xác minh Notepad tự mở hoặc Run value còn tồn tại; xác minh C:\LAB3\Evidence\task_ran.txt có chuỗi LAB3_TASK_OK.



Bước 2. Mở Autoruns. Chạy C:\LAB3\Tools\Autoruns\Autoruns64.exe bằng Run as administrator > tab Logon. Tìm LAB3_Run_Demo. Kiểm tra cột Entry, Description, Publisher, Image Path và Timestamp; không xóa mục khác.

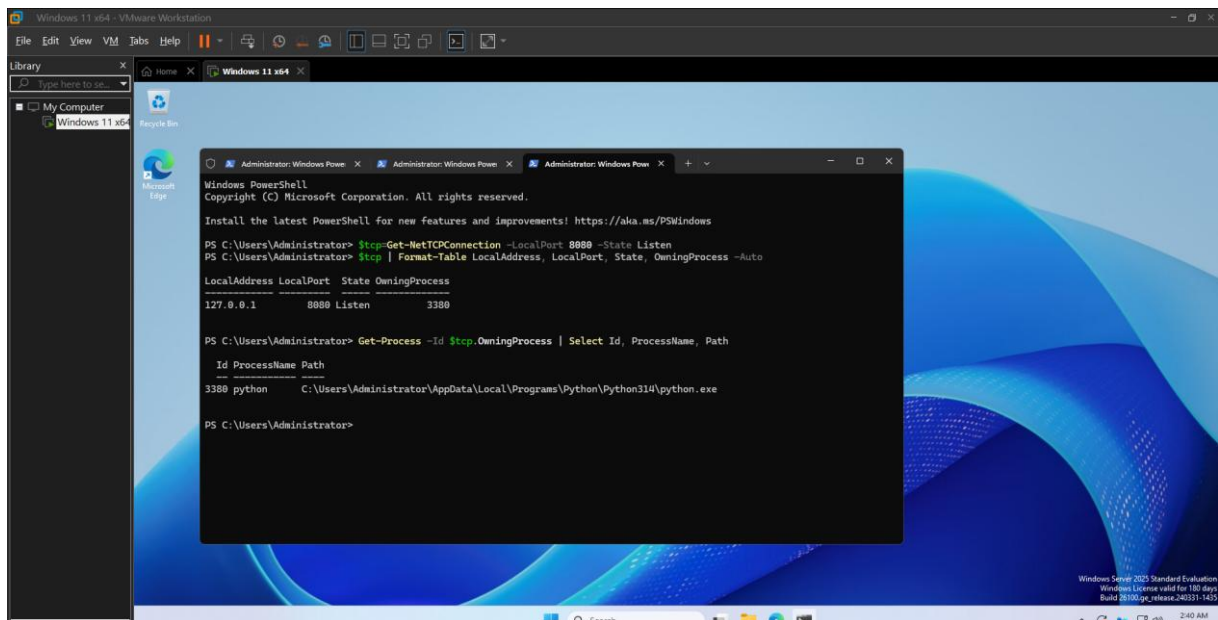


Bước 3. Truy vấn Sysmon cho Registry và process liên quan.



4.3. Tạo listener chỉ trên loopback và ánh xạ về tiến trình Bước 4. Mở một cửa sổ PowerShell không cần quyền admin và chạy HTTP server cục bộ. Giữ cửa sổ này mở trong TH4–TH6.

Bước 5. Ở cửa sổ PowerShell khác, xác minh công lắng nghe và PID.



Bước 6. Mở Process Explorer 17.14 bằng Run as administrator. Tìm PID vừa xác định, mở Properties để ghi Image, Command line, User và Verified Signer nếu có. Kết luận listener này là dịch vụ LAB được phê duyệt vì bind 127.0.0.1, có lệnh khởi chạy xác định và có bằng chứng tạo bởi chính sinh viên; không kết luận chỉ dựa vào việc “có cổng mở”.

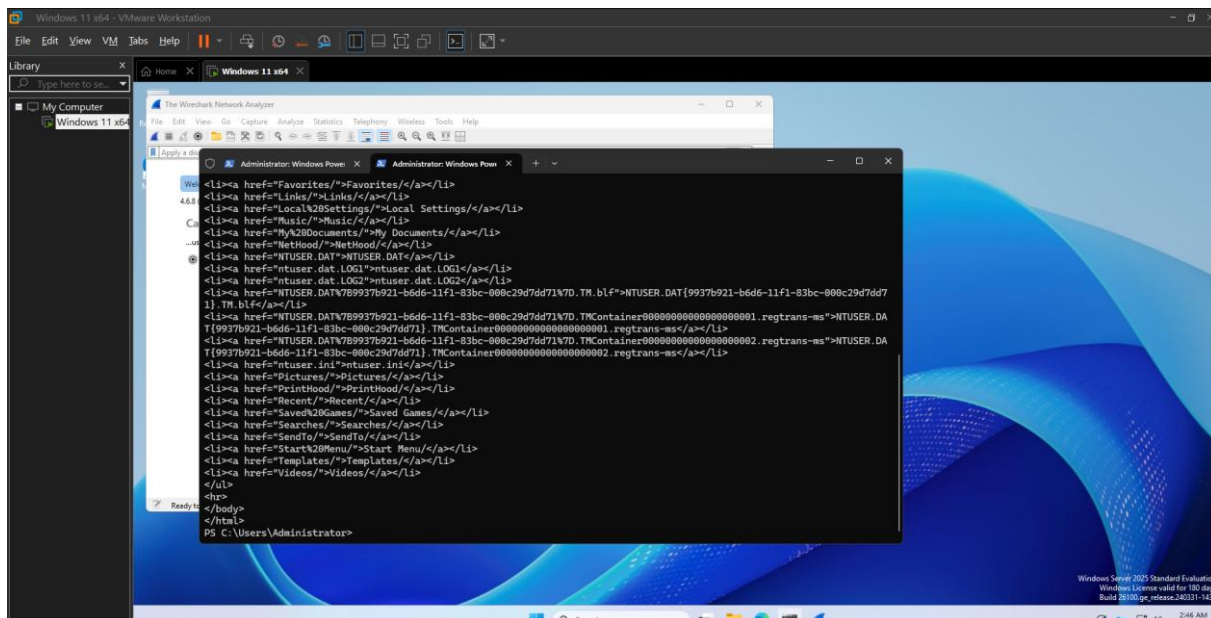
5. Tình huống 5 – Sniffing, MITM và Spoofing: quan sát HTTP so với HTTPS

Sniffing có thể được dùng hợp pháp để chẩn đoán mạng, nhưng cũng có thể bị lạm dụng để thu thập dữ liệu không mã hóa. Tình huống này chỉ capture traffic của chính VM. Không thực hiện ARP poisoning, DNS spoofing, Wi-Fi giả mạo, session hijacking hoặc chèn chứng chỉ.

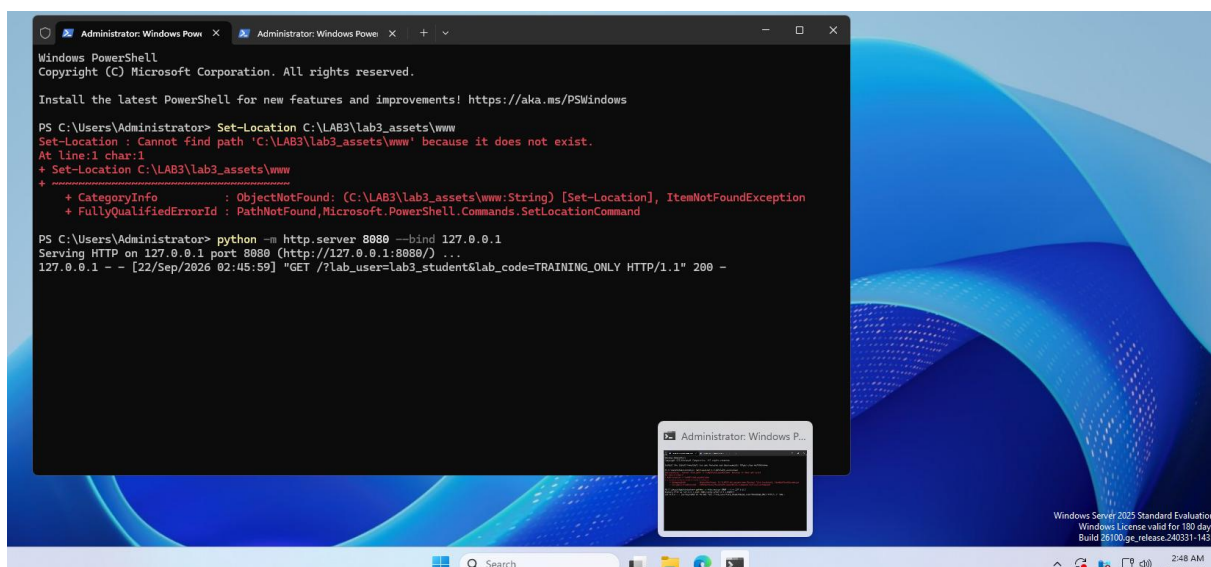
Bước 1. Mở Wireshark 4.6.8 và chọn interface loopback. Trên Windows/Npcap, chọn Adapter for loopback traffic capture hoặc interface tương ứng với 127.0.0.1. Bắt đầu capture.

Bước 2. Tạo một HTTP request có chuỗi huấn luyện trong URL. Không dùng dữ liệu thật.

Bước 3. Trong Display Filter của Wireshark nhập bộ lọc bên dưới. Chọn packet HTTP GET và quan sát Request URI trong Packet Details.



Bước 4. So sánh với HTTPS. Tạm chuyển VM sang NAT nếu cần Internet, bắt capture trên NIC hoạt động, rồi chạy lệnh dưới. Sau khi capture xong, chuyển VM về Host-only.

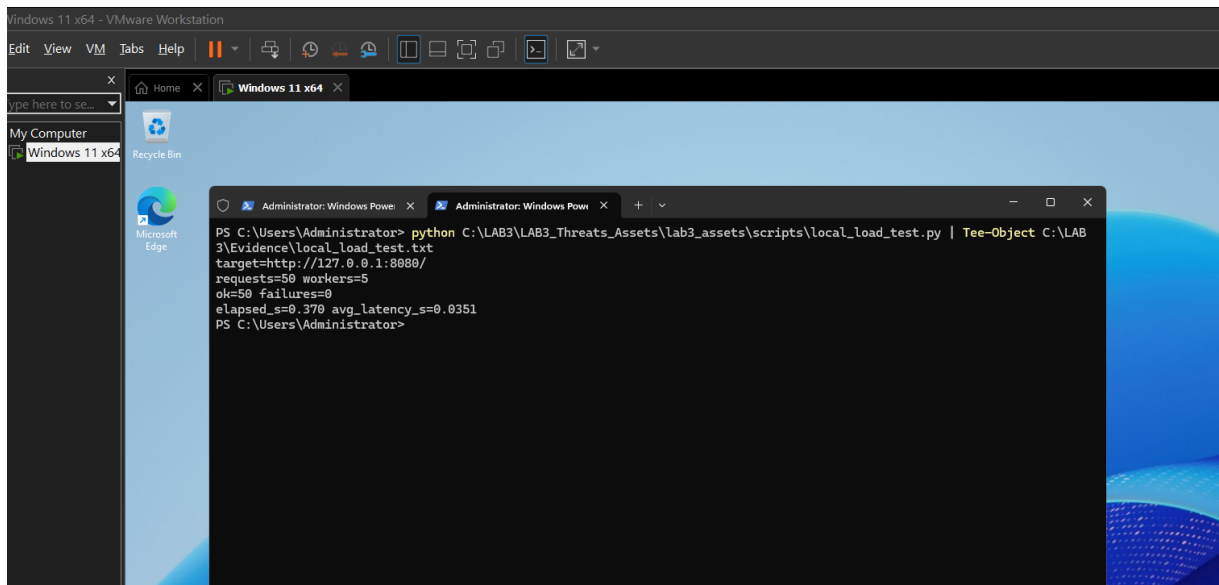


6. Tình huống 6 – DoS, DDoS và Mail Bombing

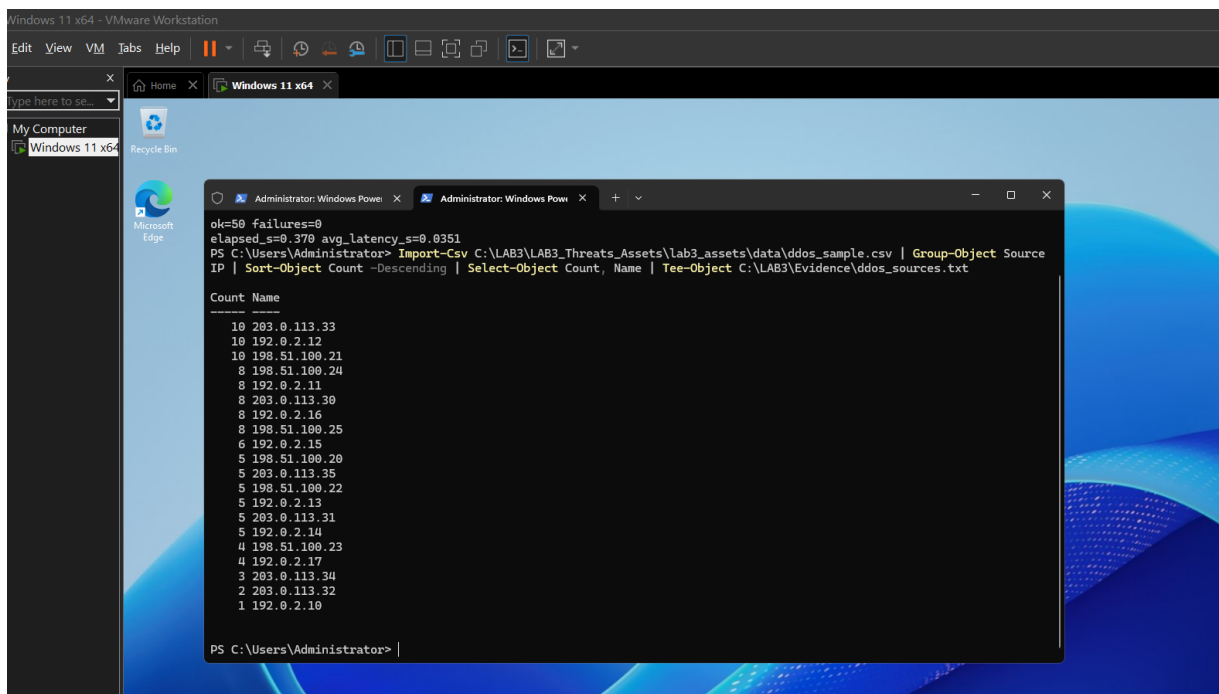
DoS nhắm vào tính sẵn sàng bằng cách làm cạn tài nguyên hoặc làm gián đoạn khả năng phục vụ; DDoS phân tán nguồn phát sinh. Mail bombing là một dạng gây tải bằng số lượng thư lớn. Bài lab không tạo DDoS và không gửi email hàng loạt. Phần thực hành gồm tải cục bộ giới hạn và phân tích dataset offline.

6.1. DoS – tải cục bộ có giới hạn

Bước 1. Đảm bảo HTTP server 127.0.0.1:8080 của TH4 vẫn đang chạy. Mở Task Manager hoặc Process Explorer để quan sát python.exe.



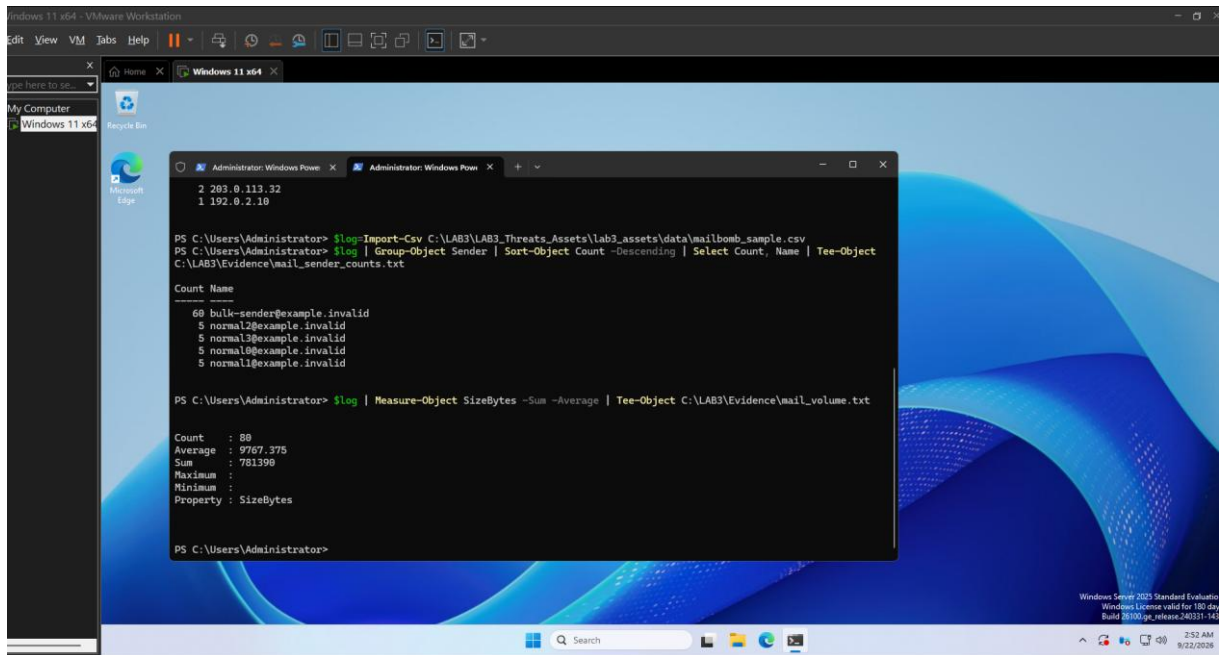
Bước 2. Chạy script có giới hạn 50 request, 5 worker. Script được hard-code 127.0.0.1:8080 và không nhận URL từ tham số.



6.2. DDoS – phân tích dataset nguồn phân tán

Dataset dùng các dải TEST-NET dành cho tài liệu. Sinh viên so sánh dấu hiệu “một nguồn tạo tải” của TH6.1 với “nhiều SourceIP” trong dataset và giải thích vì sao việc chặn một IP không đủ trong DDoS.

6.3. Mail bombing – phân tích log email offline PowerShell – thống kê volume/sender; không gửi email



```
PS C:\Users\Administrator> $log=Import-Csv C:\LAB3\LAB3_Threats_Assets\lab3_assets\data\mailbomb_sample.csv
PS C:\Users\Administrator> $log | Group-Object Sender | Sort-Object Count -Descending | Select Count, Name | Tee-Object C:\LAB3\Evidence\mail_sender_counts.txt

Count Name
-----
60 bulk-sender@example.invalid
5 normal2@example.invalid
5 normal3@example.invalid
5 normal@example.invalid
5 normal1@example.invalid

PS C:\Users\Administrator> $log | Measure-Object SizeBytes -Sum -Average | Tee-Object C:\LAB3\Evidence\mail_volume.txt

Count : 89
Average : 9767.375
Sum : 781398
Maximum :
Minimum :
Property : SizeBytes

PS C:\Users\Administrator>
```

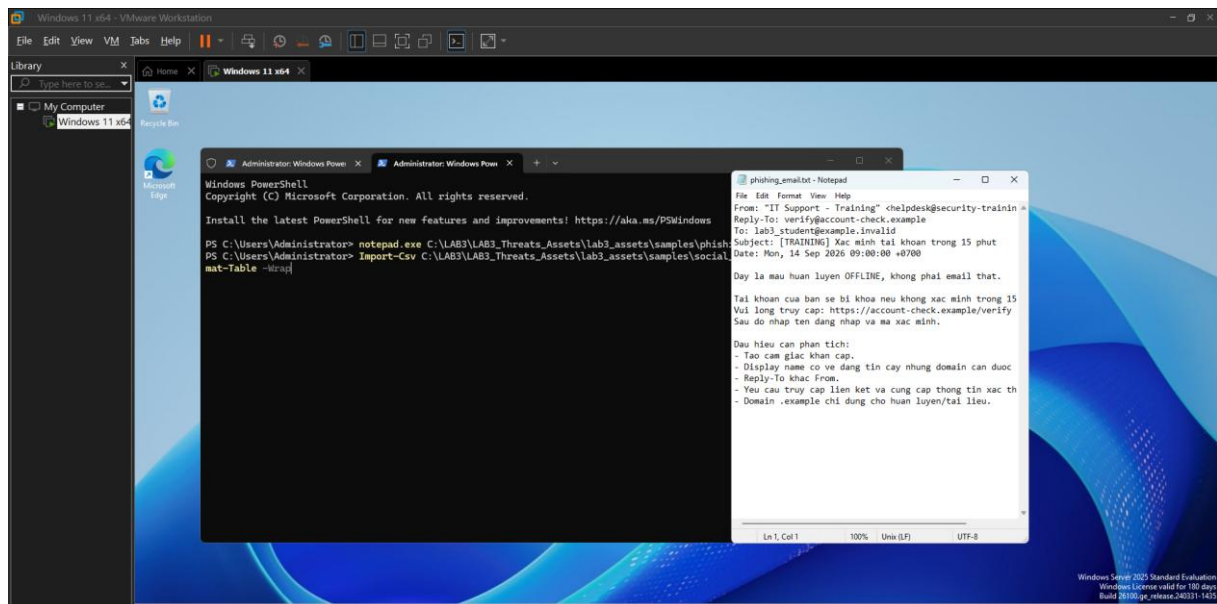
7. Tình huống 7 – Social Engineering, Phishing và Spear Phishing Social Engineering tác động vào con người để lấy thông tin hoặc khiến nạn nhân thực hiện một hành động. Bài học nêu Phishing, Watering Hole, Pretexting, Baiting và Quid Pro Quo; Spear Phishing là phishing được cá nhân hóa cho một người/tổ chức cụ thể. Tình huống này hoàn toàn offline.

Bước 1. Mở mẫu email huấn luyện bằng Notepad.

Đánh dấu tối thiểu 5 chỉ dấu: tạo cảm giác khẩn cấp, display name có vẻ đáng tin, domain cần xác minh, Reply-To khác From, yêu cầu truy cập link/cung cấp thông tin xác thực. Không truy cập domain trong mẫu; domain .example/.invalid chỉ phục vụ tài liệu/kiểm thử.

Bước 2. Phân loại các tình huống Social Engineering trong CSV.

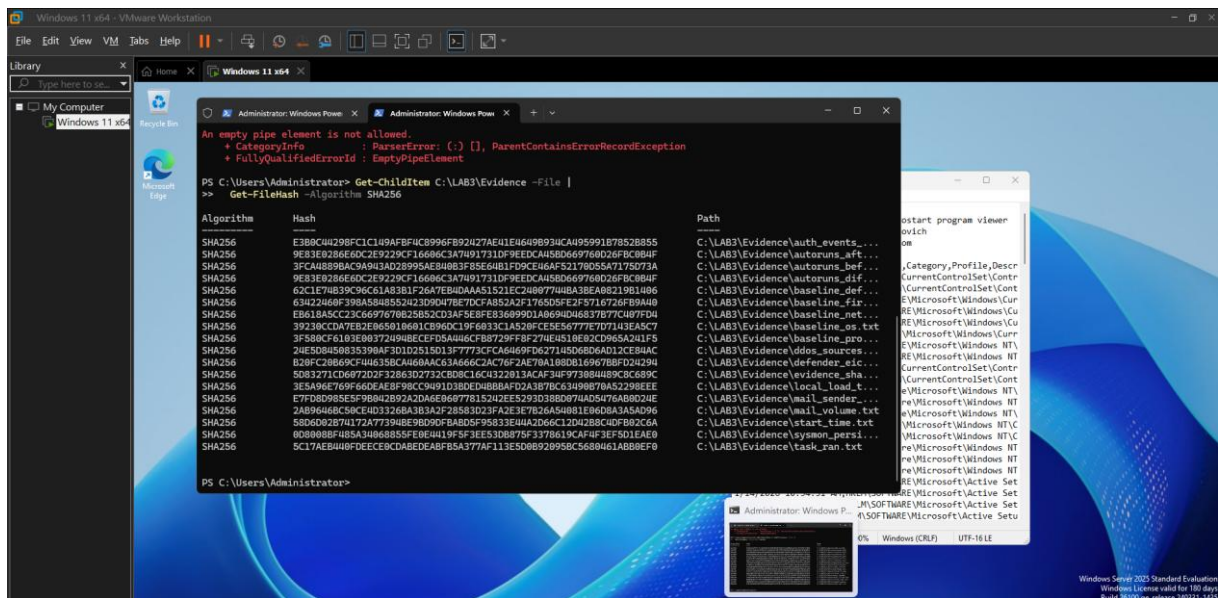
Trong báo cáo, tạo bảng CaseID → loại tấn công → dấu hiệu → biện pháp phòng tránh. Đối với Spear Phishing, chỉ ra yếu tố cá nhân hóa nào khiến thông điệp thuyết phục hơn.



8. Cô lập, cleanup, phục hồi và kiểm tra lại

Chỉ cleanup sau khi đã thu đủ bằng chứng. Các lệnh dưới đây loại bỏ artefact do bài lab tạo; không xóa entry hệ thống khác.

Bước 1. Thu baseline Autoruns sau cleanup và so sánh.



Bước 3. Khôi phục snapshot. Sau khi nộp đủ Evidence, revert VM về LAB3_CLEAN_20260914 hoặc snapshot sạch do giảng viên quy định.

C. CÂU HỎI

1. Dùng một ví dụ từ VM của bạn để phân biệt Asset, Vulnerability, Threat, Risk và Attack. Không dùng cùng một câu mô tả cho Threat và Risk.

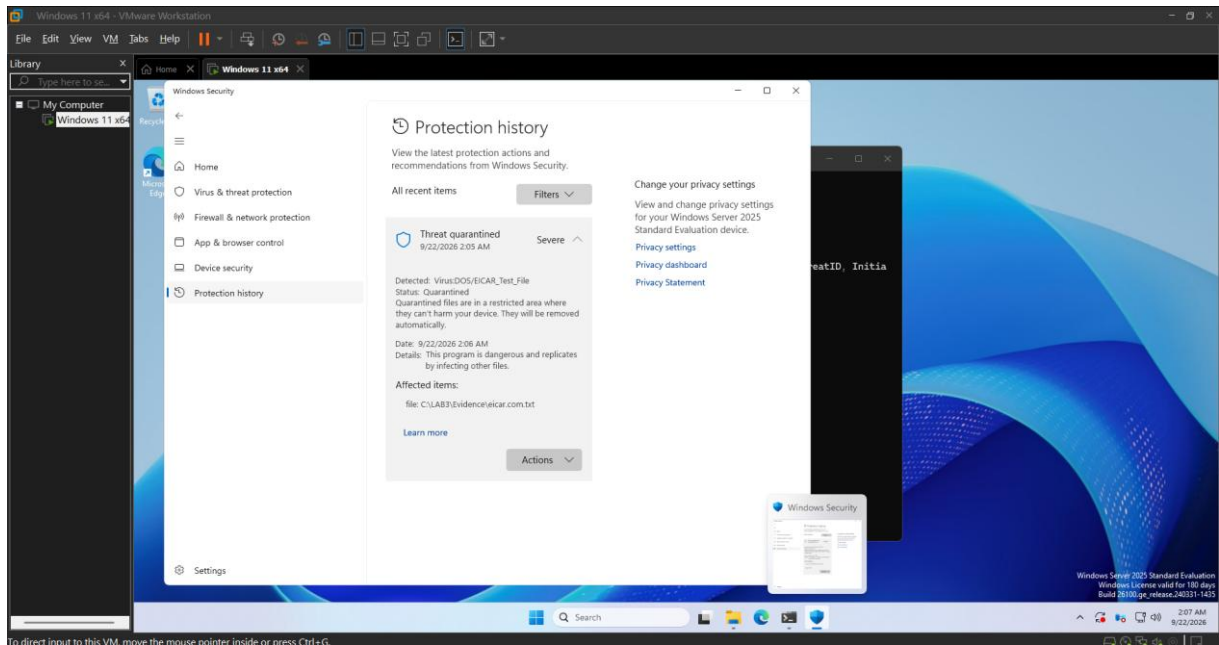
Tài sản là dữ liệu bài làm, lỗ hổng là thiếu sao lưu, mối đe dọa là hành động xóa nhầm, rủi ro là mất điểm bài tập, tấn công là khi mã độc thực sự xóa dữ liệu.

2. Phân loại năm tình huống ở TH1 thành: hành động vô ý, hành động cố ý, thảm họa tự nhiên, lỗi kỹ thuật và lỗi quản lý. Giải thích tiêu chí phân loại.

Việc xóa nhầm file là hành động vô ý, cài phần mềm thu thập dữ liệu là hành động cố ý, mất điện là thảm họa tự nhiên, hỏng ổ cứng hay lỗi phần mềm là lỗi kỹ thuật, và việc không áp dụng chính sách sao lưu là lỗi quản lý.

3. EICAR trong TH2 chứng minh được điều gì về Defender và không chứng minh được điều gì về việc có malware thật trên máy?

File EICAR chứng minh tính năng bảo vệ theo thời gian thực của Defender đang hoạt động và bắt được các mẫu đã biết, nhưng không chứng minh được máy đang nhiễm mã độc thật vì đây chỉ là file kiểm thử.



4. Vì sao không được tắt Microsoft Defender/EDR để “cho mẫu chạy”? Nếu một phần mềm hợp lệ bị chặn trong doanh nghiệp, quy trình xử lý đúng nên gồm những bước nào?

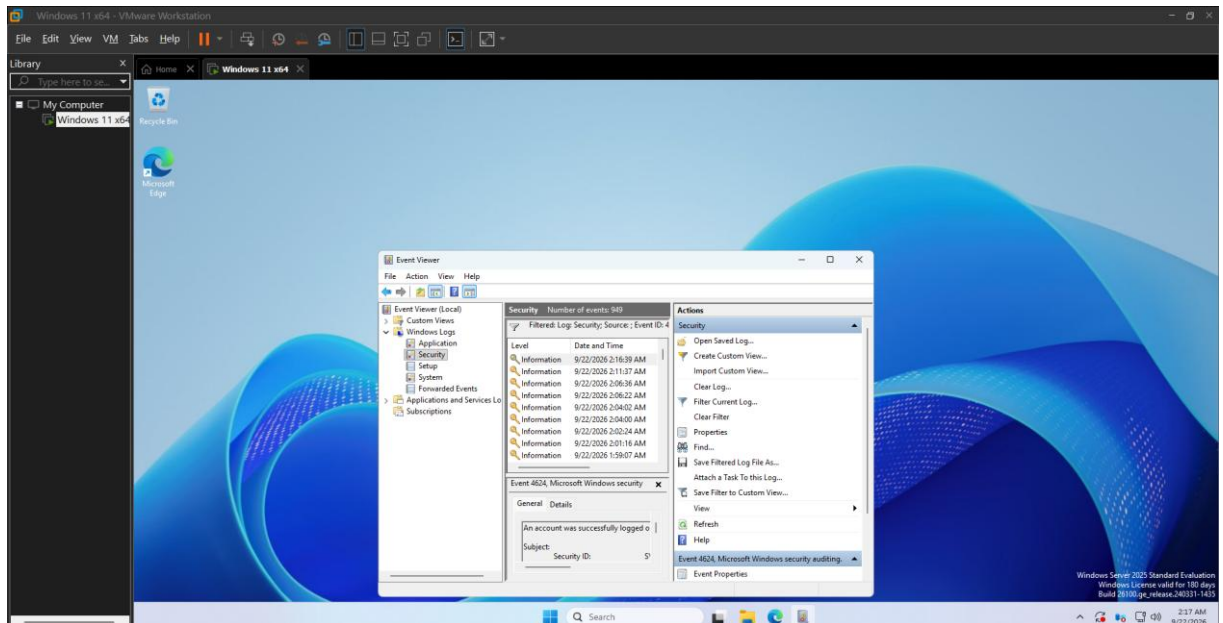
Không được tắt Defender vì sẽ làm mất lớp phòng thủ cuối cùng, tạo điều kiện cho mã độc lọt vào. Quy trình xử lý đúng: xác minh tính an toàn của file, thêm file vào danh sách ngoại lệ, sau đó khôi phục tệp từ khu vực cách ly.

5. So sánh Brute Force Attack, Dictionary Attack và Key Logger Attack về dữ liệu đầu vào, cách phát hiện và biện pháp giảm thiểu.

Brute Force thử mọi tổ hợp ký tự, Dictionary dùng danh sách từ khóa có sẵn; cả hai dễ phát hiện qua log đăng nhập sai và giảm thiểu bằng cách khóa tài khoản. Key logger ghi lại thao tác gõ phím, không tạo log lỗi nên khó phát hiện, cần phòng chống bằng xác thực đa yếu tố.

6. Dùng Event ID 4624, 4625 và 4648 của chính VM để giải thích trạng thái xác thực trước và sau khi đổi mật khẩu của lab3user.

Khi chưa đổi mật khẩu, nhập sai sinh ra Event ID 4625, nhập đúng sinh ra ID 4624 và 4648. Sau khi đổi mật khẩu, thông tin cũ vô hiệu nên nếu nhập lại sẽ tiếp tục sinh ra ID 4625.

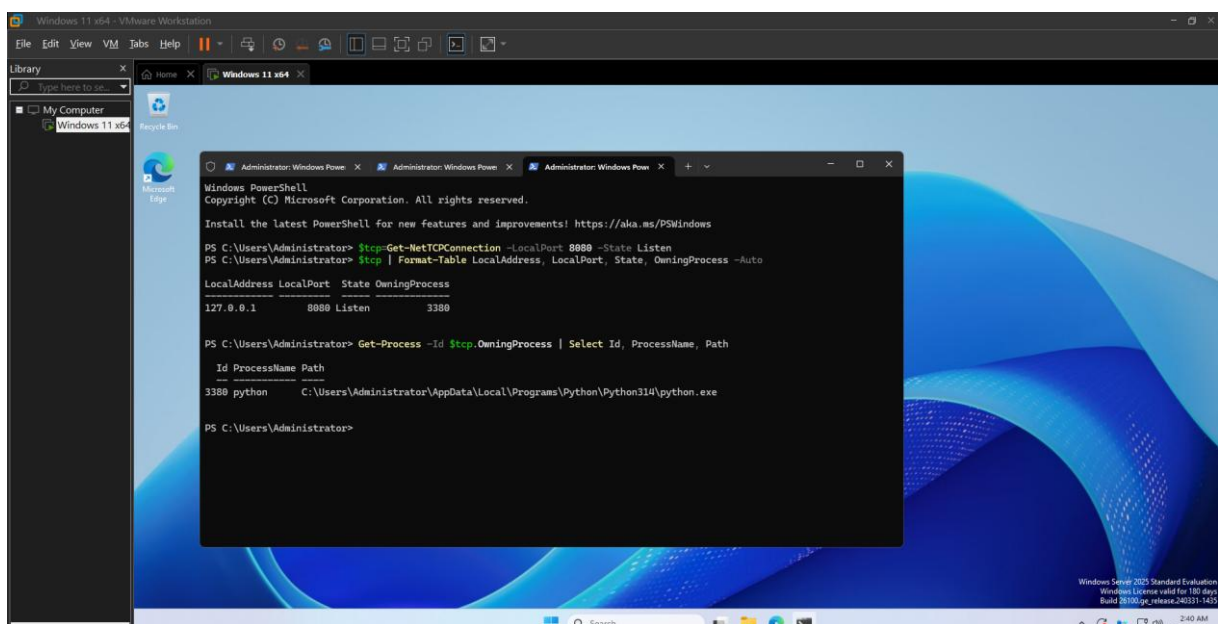
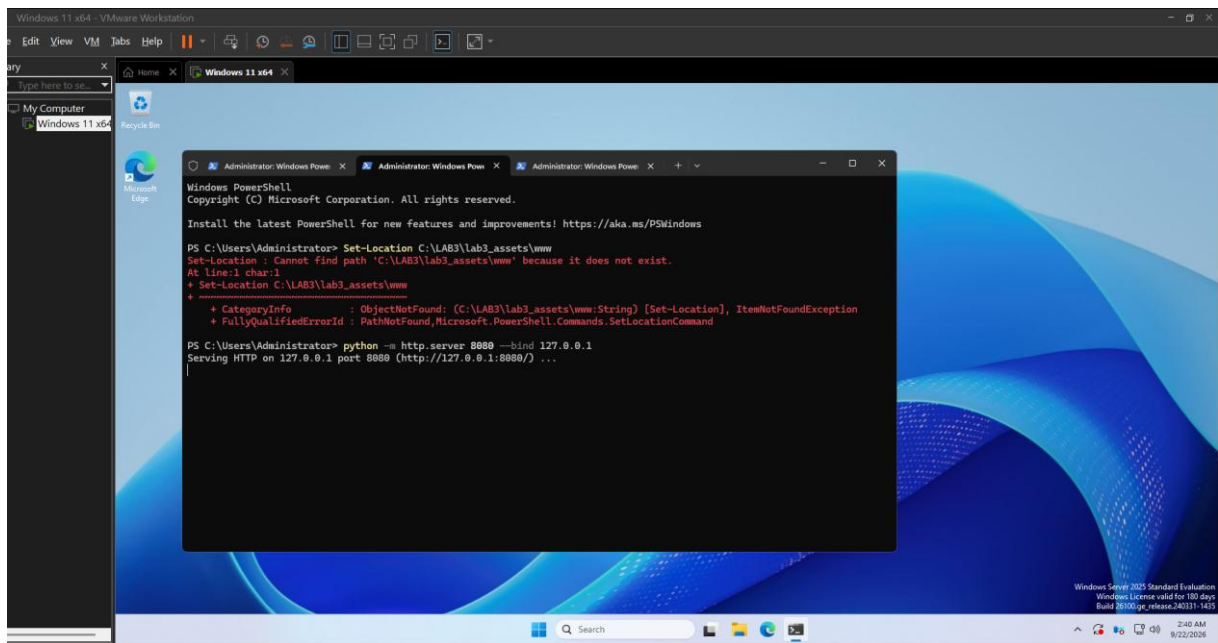


7. Vì sao mật khẩu dài/phức tạp không tự ngăn được keylogging? Phân tích thêm vai trò và giới hạn của MFA, push MFA và FIDO2/passkey.

Mật khẩu phức tạp không ngăn được keylogger vì mọi thao tác gõ phím đều bị ghi lại. MFA/push MFA thêm một lớp bảo vệ nhưng vẫn có nguy cơ bị lừa đảo lách qua. FIDO2/passkey an toàn nhất vì liên kết trực tiếp với phần cứng và kiểm tra chính xác tên miền

8. Dựa trên TH4, một công đang Listen có đủ để kết luận có backdoor không? Hãy nêu tối thiểu bốn bằng chứng phải tương quan trước khi kết luận.

Một công mạng đang Listen không đủ để kết luận có backdoor vì nhiều dịch vụ hợp lệ cũng cần mở cổng. Bốn bằng chứng cần đối chiếu: địa chỉ IP/cổng, tiến trình (PID) chiếm cổng, thông tin/chữ ký số file thực thi, và cơ chế tự khởi động.

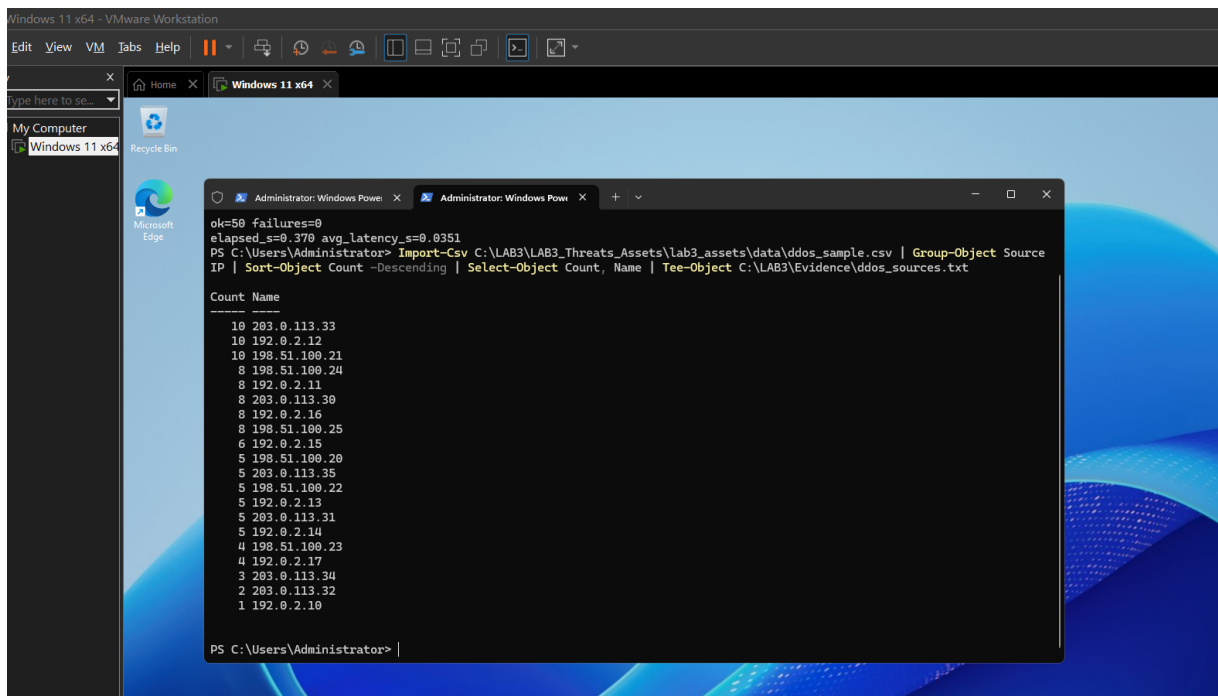


9. Run value và Scheduled Task trong TH4 tạo persistence như thế nào? Vì sao phải kiểm tra tên, đường dẫn, publisher, command line và context thay đổi trước khi xóa một entry?

Run value tự khởi chạy chương trình khi người dùng đăng nhập, Scheduled Task kích hoạt theo thời gian/sự kiện. Cần kiểm tra kỹ tên, đường dẫn và các thông số trước khi xóa để tránh vô tình gỡ bỏ các tiến trình hệ thống hợp pháp.

10. So sánh DoS và DDoS bằng kết quả local_load_test.py và ddos_sample.csv. Vì sao DDoS khó chặn chỉ bằng một rule IP đơn giản?

DoS phát sinh từ một máy tính cục bộ, trong khi DDoS dùng mạng lưới hàng ngàn máy. Vì DDoS sử dụng rất nhiều IP nguồn khác nhau nên không thể chặn đứng bằng một luật định tuyến IP đơn giản.



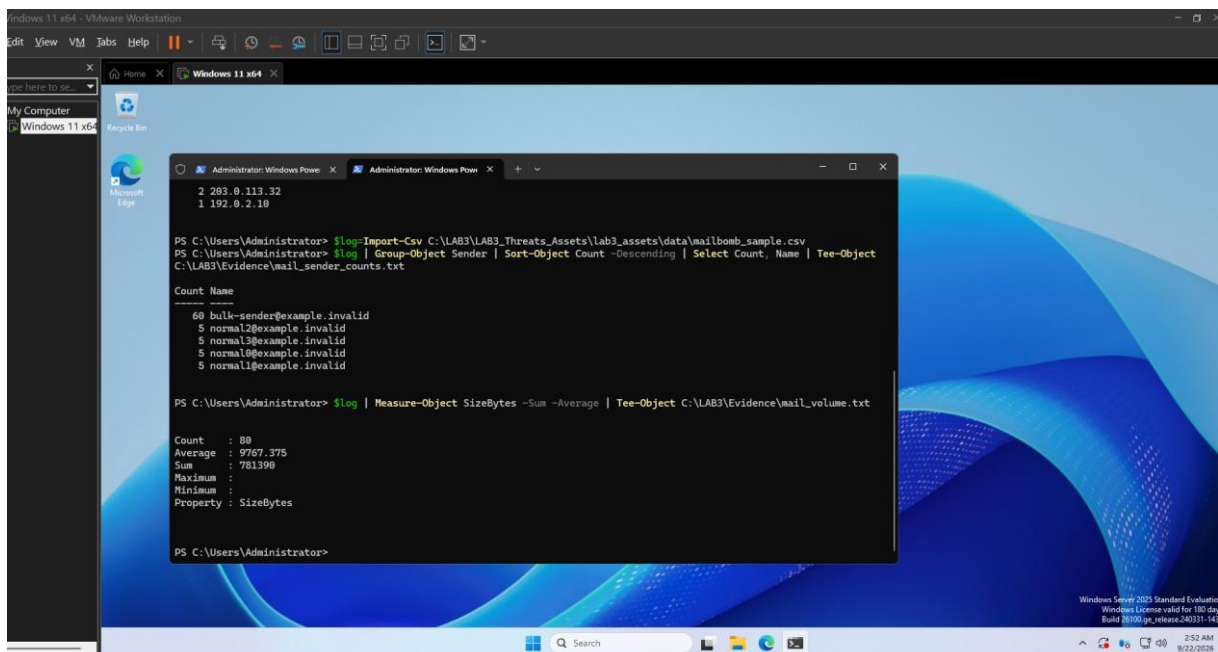
```
ok=50 failures=0
elapsed_s=0.370 avg_latency_s=0.0351
PS C:\Users\Administrator> Import-Csv C:\LAB3\LAB3_Threats_Assets\lab3_assets\data\ddos_sample.csv | Group-Object Source IP | Sort-Object Count -Descending | Select-Object Count, Name | Tee-Object C:\LAB3\Evidence\ddos_sources.txt

Count Name
-----
10 203.0.113.33
10 192.0.2.12
10 198.51.100.21
8 198.51.100.24
8 192.0.2.11
8 203.0.113.30
8 192.0.2.16
8 198.51.100.25
6 192.0.2.15
5 198.51.100.20
5 203.0.113.35
5 198.51.100.22
5 192.0.2.13
5 203.0.113.31
5 192.0.2.14
4 198.51.100.23
4 192.0.2.17
3 203.0.113.34
2 203.0.113.32
1 192.0.2.10

PS C:\Users\Administrator>
```

11. Mail bombing ảnh hưởng chủ yếu tới thuộc tính nào của hệ thống? Từ mailbomb_sample.csv, nêu hai chỉ số phù hợp để phát hiện hành vi bất thường.

Mail bombing ảnh hưởng tới tính sẵn sàng của hệ thống vì làm đầy không gian lưu trữ và nghẽn băng thông. Hai chỉ số nhận biết: tần suất gửi thư quá cao từ một tài khoản và tổng dung lượng thư tăng vọt.



```
2 203.0.113.32
1 192.0.2.10

PS C:\Users\Administrator> $log=Import-Csv C:\LAB3\LAB3_Threats_Assets\lab3_assets\data\mailbomb_sample.csv
PS C:\Users\Administrator> $log | Group-Object Sender | Sort-Object Count -Descending | Select Count, Name | Tee-Object C:\LAB3\Evidence\mail_sender_counts.txt

Count Name
-----
60 bulk-sender@example.invalid
5 normal2@example.invalid
5 normal3@example.invalid
5 normal@example.invalid
5 normal@example.invalid

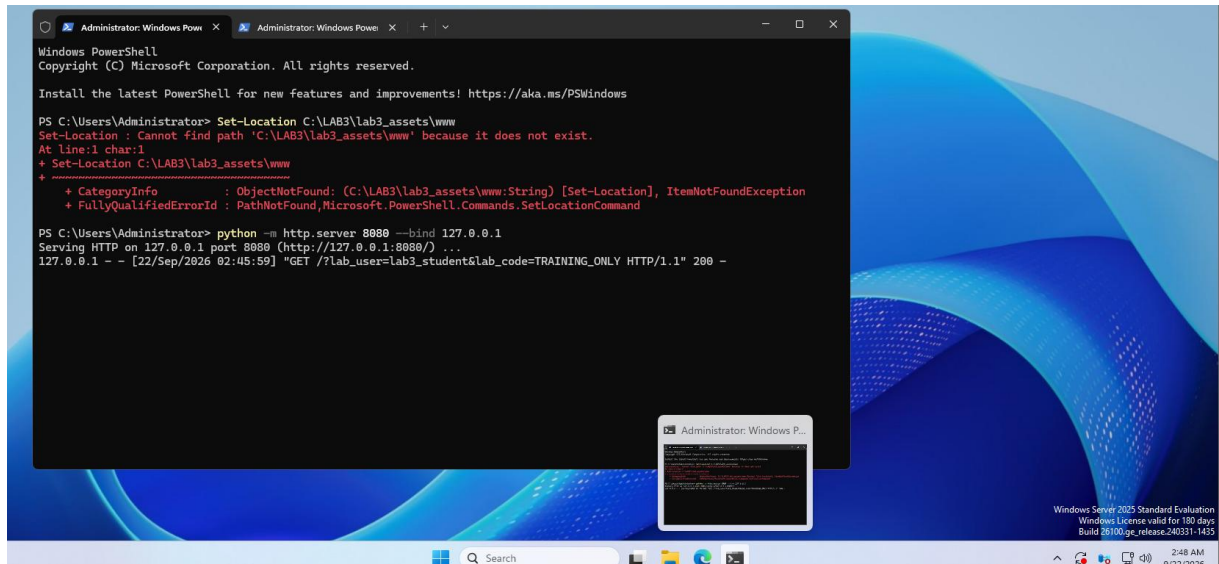
PS C:\Users\Administrator> $log | Measure-Object SizeBytes -Sum -Average | Tee-Object C:\LAB3\Evidence\mail_volume.txt

Count      : 80
Average    : 9767.375
Sum        : 781390
Maximum    :
Minimum    :
Property   : SizeBytes

PS C:\Users\Administrator>
```

12. Sniffing có thể được dùng hợp pháp và bất hợp pháp như thế nào? Dùng hai capture của TH5 để minh họa sự khác nhau giữa HTTP và HTTPS.

Sniffing hợp pháp khi dùng để phân tích lỗi mạng, bất hợp pháp khi dùng để nghe lén thông tin. HTTP để lộ toàn bộ dữ liệu dưới dạng văn bản rõ, trong khi HTTPS mã hóa hoàn toàn nội dung payload.



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Administrator> Set-Location C:\LAB3\lab3_assets\www
Set-Location : Cannot find path 'C:\LAB3\lab3_assets\www' because it does not exist.
At line:1 char:1
+ Set-Location C:\LAB3\lab3_assets\www
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (C:\LAB3\lab3_assets\www:String) [Set-Location], ItemNotFoundException
+ FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.SetLocationCommand

PS C:\Users\Administrator> python -m http.server 8080 --bind 127.0.0.1
Serving HTTP on 127.0.0.1 port 8080 (http://127.0.0.1:8080/) ...
127.0.0.1 - - [22/Sep/2026 02:45:59] "GET /?lab_user=lab3_student&lab_code=TRAINING_ONLY HTTP/1.1" 200 -
```

13. Trình bày Email Hijacking, Wi-Fi Eavesdropping, Session Hijacking và IP/DNS/HTTPS Spoofing trong bối cảnh Man-in-the-Middle. Kỹ thuật nào không được thực hiện chủ động trong lab và vì sao?

Email Hijacking là đánh chặn thư, Wi-Fi Eavesdropping là nghe lén mạng không dây, Session Hijacking trộm phiên đăng nhập, Spoofing giả mạo định tuyến. Không thực hiện chủ động trong lab vì có thể làm gián đoạn và gây mất an toàn cho mạng thực tế.

14. HTTPS, HSTS và VPN giảm rủi ro MITM theo những cơ chế nào? Nêu ít nhất hai loại rủi ro mà các biện pháp này không tự giải quyết.

Email Hijacking là đánh chặn thư, Wi-Fi Eavesdropping là nghe lén mạng không dây, Session Hijacking trộm phiên đăng nhập, Spoofing giả mạo định tuyến. Không thực hiện chủ động trong lab vì có thể làm gián đoạn và gây mất an toàn cho mạng thực tế.

15. Phân biệt spoofing ở lớp IP, DNS và website/domain. Với mỗi loại, nêu một nguồn bằng chứng hoặc kiểm soát phù hợp.

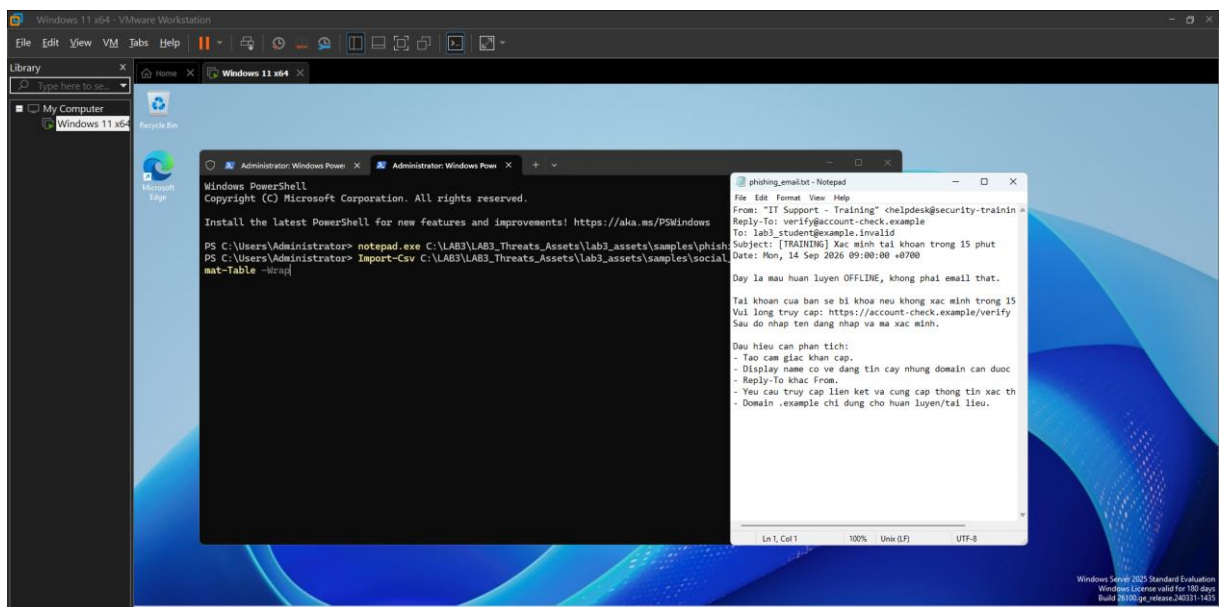
Spoofing IP giả mạo địa chỉ nguồn, Spoofing DNS trả về IP độc hại cho tên miền đúng, Spoofing website làm nhái giao diện. Kiểm soát tương ứng: tường lửa lọc gói tin, sử dụng DNSSEC, và huấn luyện người dùng kiểm tra chứng chỉ SSL.

16. Từ `social_engineering_cases.csv`, phân biệt Phishing, Spear Phishing, Watering Hole, Pretexting, Baiting và Quid Pro Quo.

Phishing lừa đảo qua email diện rộng, Spear Phishing nhắm mục tiêu cá nhân, Watering Hole lây nhiễm trang web mục tiêu hay xem, Pretexting dựng kịch bản giả danh, Baiting dùng vật mồi nhử, Quid Pro Quo dụ dỗ trao đổi lợi ích.

17. Trong `phishing_email.txt`, những chỉ dấu nào liên quan tới “uy tín giả”, “khẩn cấp”, “domain”, “Reply-To” và “yêu cầu credential”?

Dấu hiệu: dùng tên tổ chức uy tín (uy tín giả), ép buộc hành động ngay (khẩn cấp), tên miền lạ sai chính tả (domain), địa chỉ phản hồi không khớp người gửi (Reply-To), và yêu cầu truy cập link lạ để đăng nhập (yêu cầu credential).



18. Xây dựng quy trình incident response ngăn cho endpoint nghi có keylogger/backdoor: triage → preserve evidence → contain → credential action → eradicate → recover → monitor.

Phân loại mức độ sự cố (Triage) → Lưu trữ bằng chứng (Preserve evidence) → Cách ly máy khỏi mạng (Contain) → Yêu cầu đổi mật khẩu (Credential action) → Gỡ

bỏ mã độc (Eradicate) → Khôi phục lại hệ thống (Recover) → Tiếp tục giám sát (Monitor).

19. SHA-256 trong bài giúp chứng minh điều gì về tính toàn vẹn của file Evidence và không chứng minh điều gì về nguồn gốc hay tính đúng đắn của nội dung?

Mã SHA-256 chứng minh tính toàn vẹn của tệp tin (tệp không bị chỉnh sửa). Nó không chứng minh được nguồn gốc, nội dung có đúng sự thật không, hoặc tệp đó có chứa mã độc hay không.

20. Đề xuất defense-in-depth cho một máy phòng kế toán hoặc máy quản trị: endpoint protection, least privilege, application control, logging, network control, backup và credential protection.

Đề xuất bảo vệ đa lớp: Cài phần mềm bảo vệ điểm cuối (EDR), dùng tài khoản Standard (least privilege), giới hạn ứng dụng được chạy (application control), ghi log hệ thống, thiết lập tường lửa mạng, sao lưu dữ liệu theo nguyên tắc 3-2-1 và dùng khóa phần cứng bảo vệ xác thực.